Triage de alertas SOC sobre 2M de eventos con modelos tabulares, de texto y de grafo

Propuesta de proyecto — Aprendizaje Automático (Primera entrega)

Author Name

8va sesión · 15 min + 5 min preguntas

Índice

Introducción

Trabajo previo

Metodología

Experimentos

Conclusión

1. Contexto

- Un SOC vigila con decenas de productos: firewalls, EDR, identidad, nube, hipervisores, DNS.
- WitFoo Precinct normaliza y correlaciona con **261 reglas de detección**; agrupa señales en **incidentes** (señales + subgrafo de proveniencia + reporte).
- Dataset: `precinct6-cybersecurity` v2.1.0 — **2,011,674 eventos** en 6 días (26 jul–01 ago 2024), 4 organizaciones, 19 productos, 12 fabricantes.

1. Motivación

- **Volumen**: 2M de eventos en 6 días, imposible a mano.
- **Desbalance extremo**: 0.38 % malicioso (IR 245:1) $\rightarrow$ accuracy miente (94.31 % con siempre-benigno).
- **Asimetría de costos**: FN (brecha) $>>$ FP $\rightarrow$ optimizar recall minoritario, no exactitud.
- **Contexto del analista**: decidir exige mensaje + MITRE + cadena, no un número.

1. Pregunta de investigación

Objetivo: estimar el nivel de riesgo de un evento con probabilidades calibradas y recomendación operativa.

> *¿Es posible recuperar eventos maliciosos con desbalance 245:1 y deriva temporal combinando representaciones tabulares, textuales y estructurales, y qué compromiso existe con el nivel intermedio?*

Específicos: (i) caracterizar datos y leakage; (ii) $\geq$5 preprocesos; (iii) 3 modelos con complejidad; (iv) desplegar servicio + consola.

2. Marco de referencia

Tres familias:

- **Grafos de proveniencia**: NODLINK (APT online), KnowHow (CTI interpretable), FLASH (GNN temporal), threaTrace/GraphSAGE (nivel de nodo).
- **Mapeo a ATT&CK desde texto**: TRAM (MITRE, + notebooks SciBERT), comparativas TF-IDF vs transformers.
- **Desbalance**: Focal Loss; formulaciones sensibles al costo (FN $>>$ FP).

Dos casos se analizan en detalle, uno por estructura y otro por texto.

2. Caso 1: Devign (NeurIPS 2019)

Enfoque: GNN (GGNN + módulo Conv) sobre representación compuesta del código (AST + dependencias de control/datos). Tarea: **binaria a nivel función** (¿vulnerable?).

- **Datos**: etiquetados manualmente, ∼600 h-persona, 4 librerías C (Linux, QEMU, Wireshark, FFmpeg); código real complejo.
- **Resultado**: **+10.51 % accuracy / +8.68 % F1** vs baselines; +27.99 % F1 vs analizadores estáticos; 74.11 % en 40 CVEs nuevos.

Lección: precedente del componente de grafo. Contraste: etiquetas caras/limpias vs nuestras automáticas/ruidosas.

2. Caso 2: CVSS-BERT (IEEE ICMLA 2021)

Enfoque: trabaja con **texto, no código**. **8 clasificadores BERT**, uno por métrica del vector CVSS, desde la descripción del CVE (45,926 CVEs 2018–2020).

- **Motivación**: al publicarse una vuln solo hay descripción; el análisis experto tarda días.
- **Resultado**: accuracy 83.79–96.07 % por métrica; severidad MAE 0.73, 55.3 % match exacto $\rightarrow$ muy cerca del experto. Incluye saliency explicable.
- **Limitación**: los puntajes CVSS **varían según quién asigna** (hasta 0.8 pts NVD vs otros; 1.3 por versión; degradación aguas abajo hasta 77 %) $\rightarrow$ etiquetas dependen del contexto.

Lección: precedente del componente de texto; su límite fundamenta nuestras limitaciones.

2. Síntesis y brecha

	Devign	CVSS-BERT	Propuesto
Entrada	grafo código	texto CVE	tabular + texto + subgrafo
Tarea	binaria	8 métricas $\rightarrow$ puntaje	3 niveles + ATT&CK
Etiquetas	manuales 600 h	NVD experto	Precinct automático
Señal	+10.51 % acc	MAE 0.73	cascada + compromiso

Brecha: la literatura opera sobre código o descripciones de vulnerabilidades, no sobre telemetría de operación en tiempo real con desbalance extremo, deriva temporal y humano en el bucle.

3. Definición del problema

Clasificación supervisada multiclase: $f : x \mapsto (y, p)$ con $y \in \{\text{benign, suspicious, malicious}\}$.
Representación x en tres niveles:

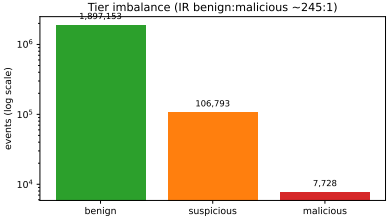
- campos tabulares del evento;
- mensaje crudo saneado;
- subgrafo de vecindario temporal (± 5 min).

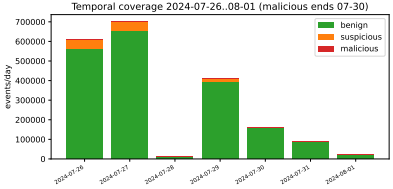
Condicionantes: desbalance 245:1, distribución no estacionaria, humano en el bucle.

3. Dataset y exploración

Nivel	Eventos	%
benign	1,897,153	94.31
suspicious	106,793	5.31
malicious	7,728	0.38

Además: 238,511 señales históricas, 47,585 nodos / 1,740,438 aristas, 51,371 incidentes con reporte.





3. Preprocesamiento (P1–P5)

- **P1** Codificación categórica consciente del saneamiento (ausentes = nivel propio, no mediana).
- **P2** Características temporales + partición temporal anti-leakage.
- **P3** Desbalance: muestreo estratificado + ponderación de clases (sin SMOTE sobre codificadas).
- **P4** Vectorización del texto del registro (TF-IDF 5k).
- **P5** Subgrafo de vecindario ± 5 min por host/credencial.

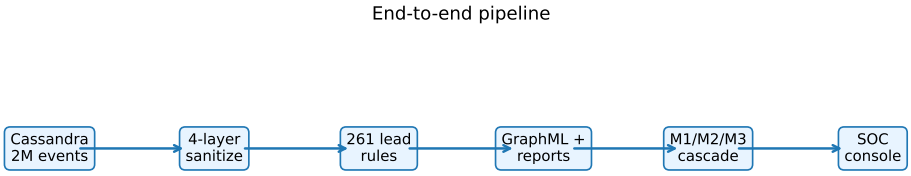
Cumple el requisito de al menos tres metodologías.

3. Modelos y complejidad

- **M1 tabular** (gradient boosting, ponderado): fit crece con árboles$\times$filas$\times$características; inferencia = recorrido raíz-hoja.
- **M2 texto**: concatena vectorización del mensaje + tabular; costo extra lineal en longitud del mensaje.
- **M3 grafo**: agrega vecindario en ventana y alimenta clasificador; costo por evento según tamaño del vecindario.

Cascada de servicio: M1 ordena la cola $\rightarrow$ M2 confirma con evidencia textual $\rightarrow$ M3 confirma con evidencia estructural.

3. Diagrama del proceso



Desde la captura y saneamiento, pasando por las 261 reglas y el preprocesamiento, hasta la cascada de modelos y la consola del analista.

3. Protocolo de evaluación

- **Partición temporal**: entrenar con el pasado, evaluar con el futuro (corte = cuantil 80 de la marca de tiempo).
- **Métricas**: F1-macro y área bajo precisión-recuerdo por clase; recall malicioso a FPR fijo.
- La exactitud se reporta solo para mostrar que no es informativa bajo IR 245:1.
- Se documentarán semillas e infraestructura para permitir replicación.

4. Experimentos planeados

- **E1 (base tabular)**: M1 sobre campos. Hipótesis: recupera benign/suspicious, colapsa en malicious $\rightarrow$ línea base honesta.
- **E2 (texto)**: M2 + mensaje. Hipótesis: eleva sustancialmente el recall malicioso (vocabulario de explotación).
- **E3 (estructura)**: M3 + vecindario. Hipótesis: iguala E2 por mecanismo distinto y refleja movimiento lateral.

Ablaciones: (i) codificación del texto (frecuencias vs contextual); (ii) radio de la ventana temporal.

4. Análisis previsto y despliegue

- Matriz de confusión normalizada por fila: hacia qué clase se desplaza el error minoritario.
- Explicitar el **compromiso**: recuperar la clase minoritaria vs preservar el nivel intermedio.
- **Despliegue**: servicio FastAPI en :8000 (`/score`, `/queue`, `/incident`) + consola React en el mismo origen (Docker multi-stage), con bitácora de feedback para re-entrenar.

5. Limitaciones y trabajo futuro

Limitaciones previstas

- Etiquetas de correlación automática, no de analista (oráculo imperfecto; mayoría sin procesar).
- Distribución desigual por tiempo y organización $\rightarrow$ generalización restringida.
- Análogo a CVSS: la etiqueta **depende del asignador** y su contexto.

Trabajo futuro

- Predicción multi-etiqueta de técnicas ATT&CK.
- Codificadores contextuales entrenables sobre los reportes de incidente.

Referencias

Devign (NeurIPS 2019, arXiv:1909.03496) · CVSS-BERT (ICMLA 2021, arXiv:2111.08510) · Schwab & Gwerder (Berna, 2020) · LADC 2024 (doi 10.1145/3697090.3697109) · arXiv:2112.10356 · NODLINK (2311.02331) · KnowHow (2509.05698) · FLASH (S&P 2024) · threaTrace (2111.04333) · GraphSAGE (1706.02216) · TRAM (MITRE CTID) · TF-IDF vs transformers (2407.06753) · Focal Loss (1708.02002) · Cost-sensitive IDS (0807.2043) · ATT&CK `https://attack.mitre.org/` · Dataset `https://huggingface.co/datasets/witfoo/precinct6-cybersecurity`